Tema 5
Seguridad en redes WLAN

Tecnologías para las comunicaciones inalámbricas

Contenidos

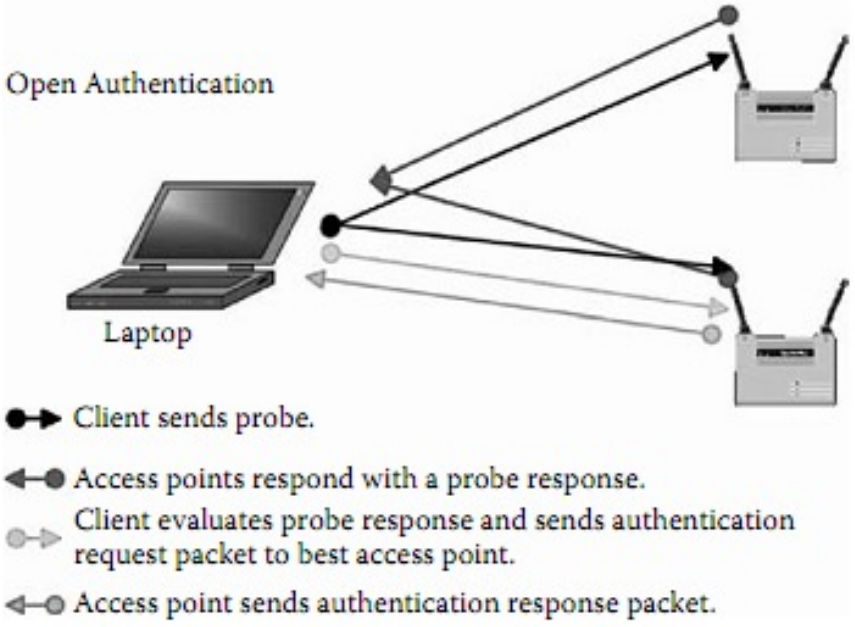
- **Autenticación WLAN**
- **AAA**
- **eduroam**
- **WEP**
- **802.11i**
- **Wi-Fi Protected Setup**
- **Portal cautivo**
- **Resumen y consideraciones finales**

Autenticación WLAN

- Autenticación
  - Hay que asegurar que las estaciones que desean unirse a una red 802.11 están autorizadas para ello
  - El estándar propone dos métodos:
    - Autenticación de sistema abierto (open-system)
    - Autenticación de clave compartida (shared-key)
  - Estos métodos sólo "prueban" la identidad de la estación
    - El punto de acceso en las redes infraestructura no es autenticado
    - Buen punto de ataque para introducir AP falsos

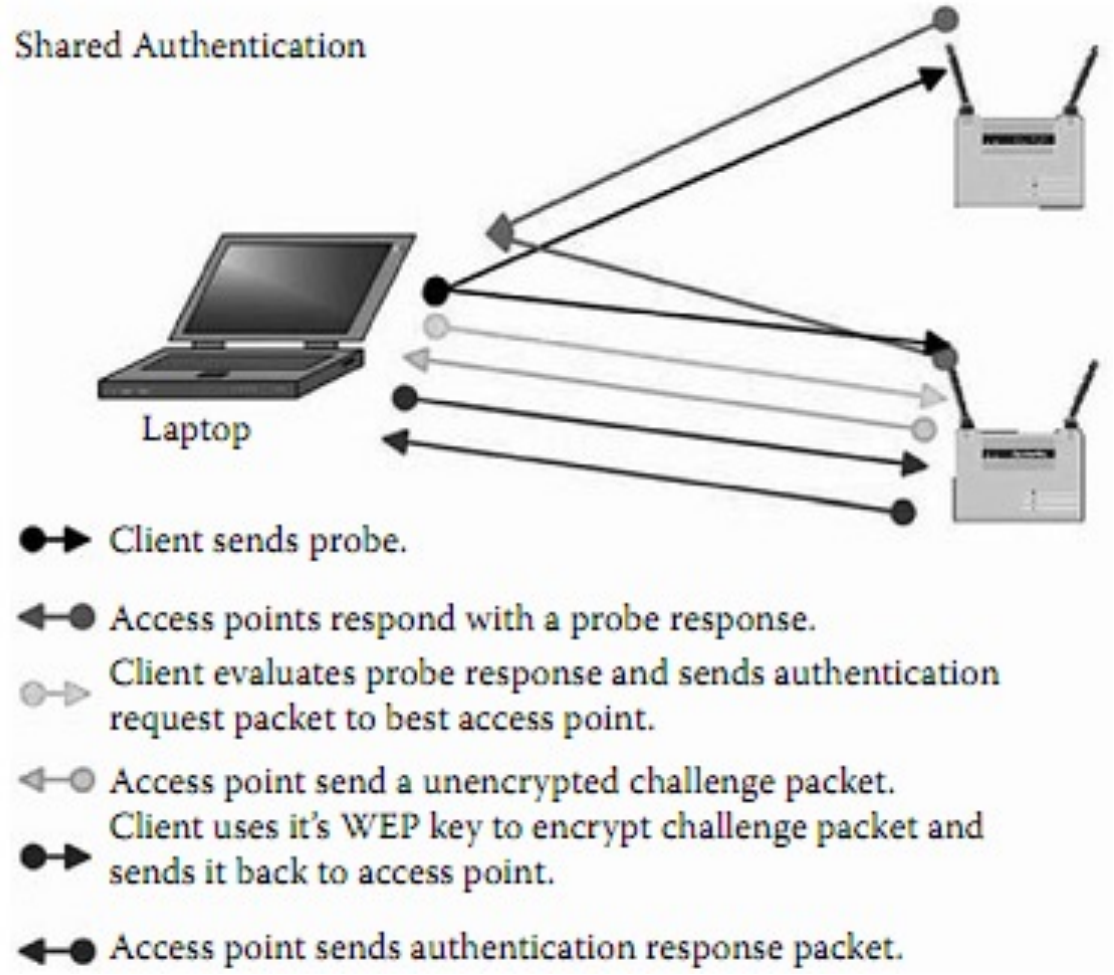
Autenticación WLAN

- Autenticación de sistema abierto
  - No se le puede llamar autenticación, puesto que no hace nada
  - En realidad es un mecanismo que delega en autenticación de nivel superior
  - Posibilidades derivadas de este tipo de autenticación
    - Filtrado por direcciones MAC de las estaciones
    - Encapsulamiento de protocolos de autenticación (802.1X)



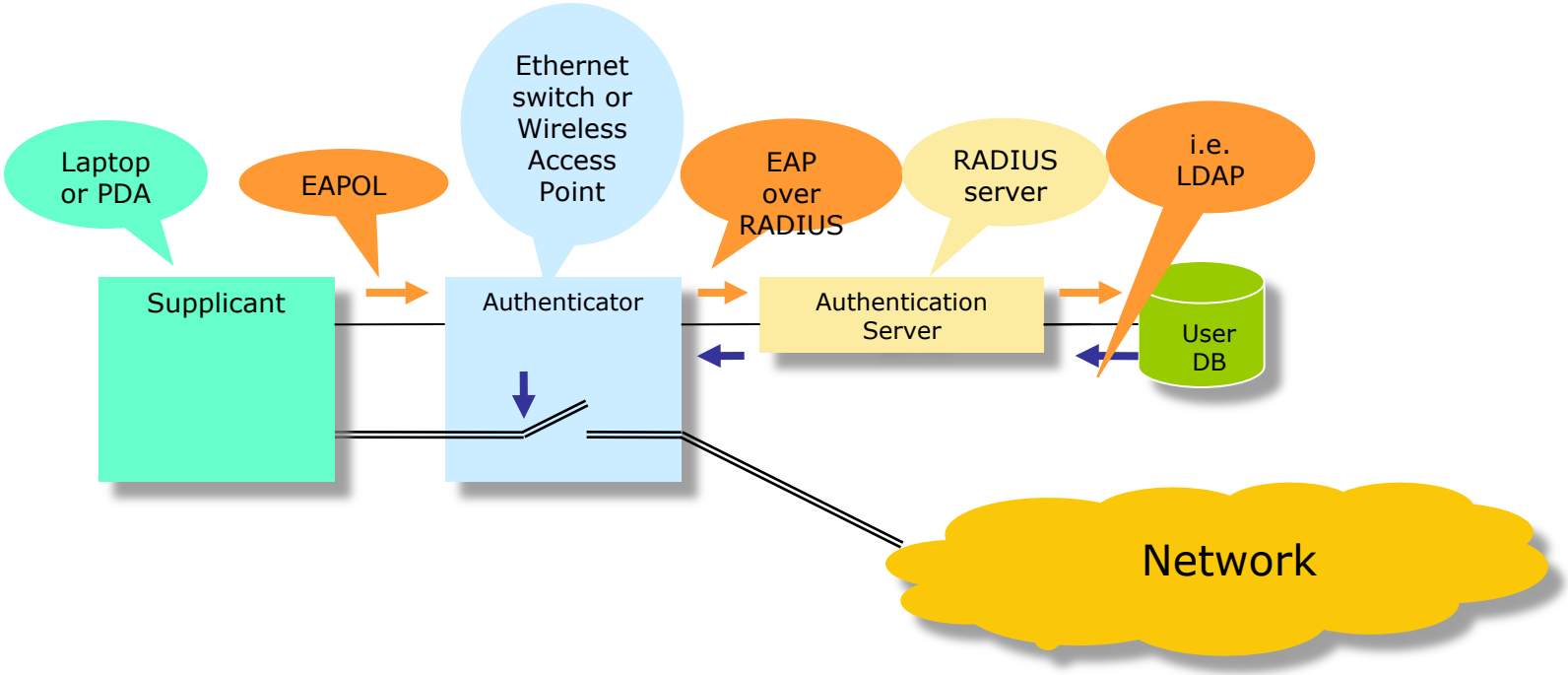
Autenticación WLAN

- Autenticación de clave compartida
  - Hace uso del cifrado WEP de un desafío



Arquitectura 802.1X

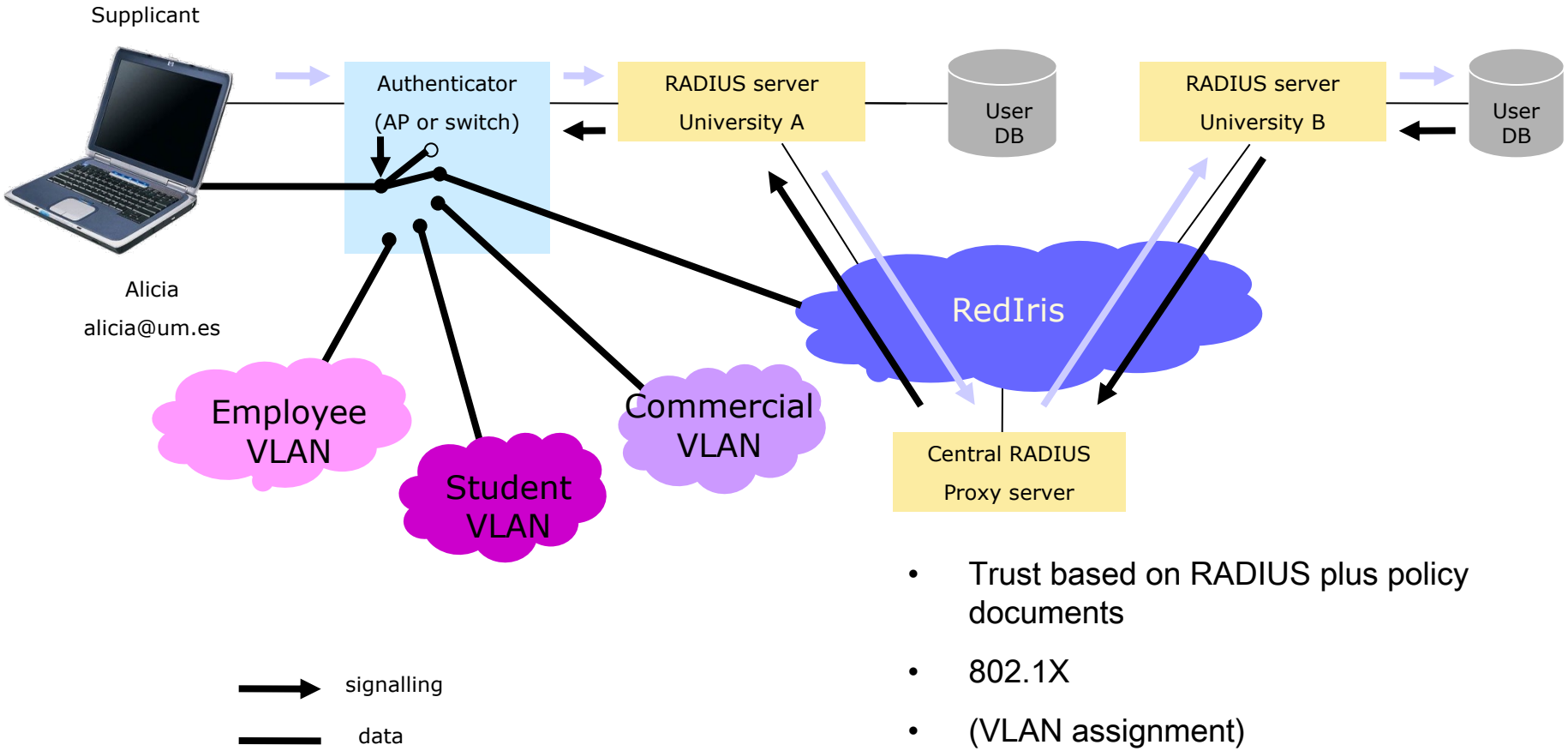
- Funcionamiento general



eduroam

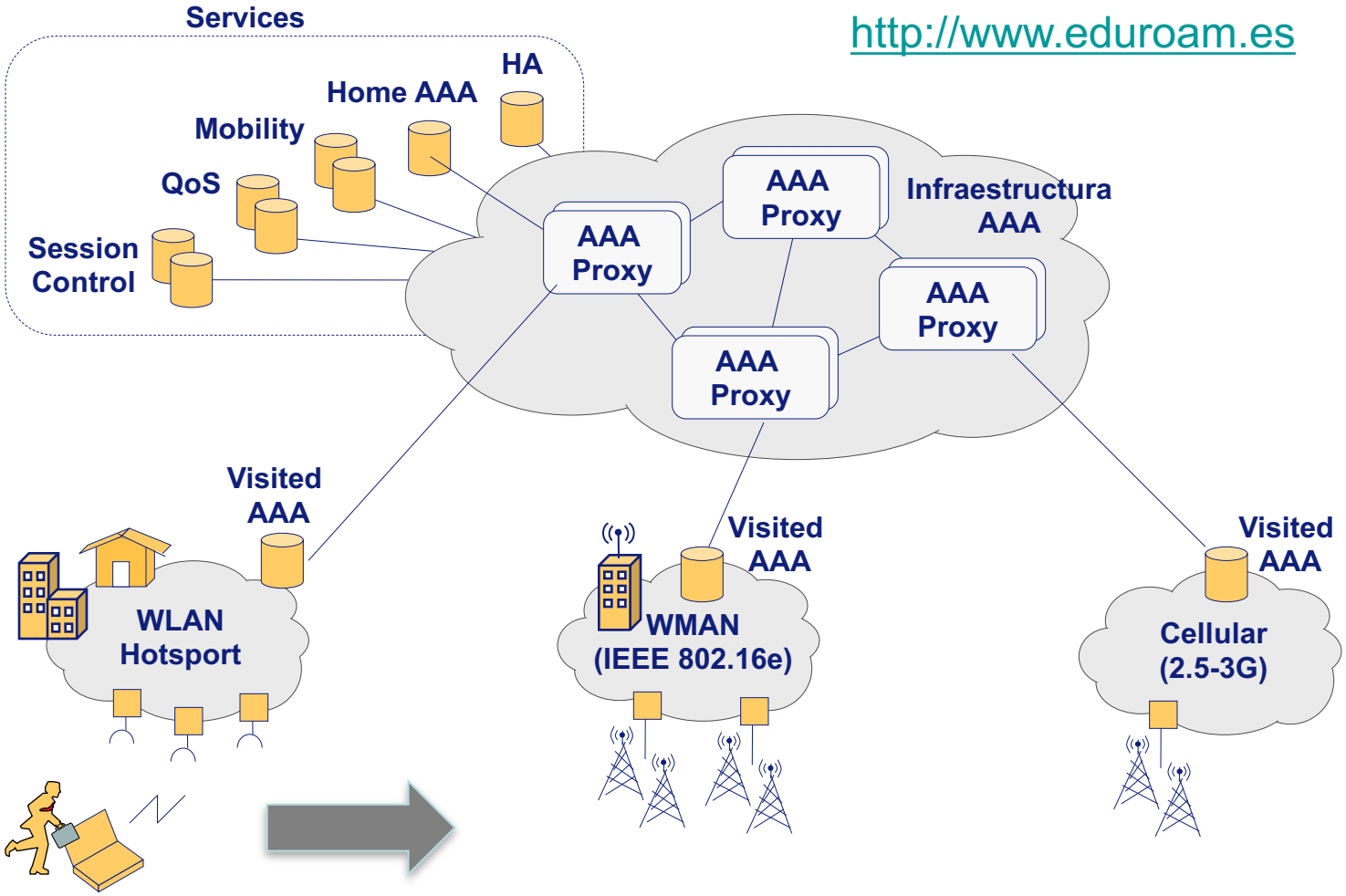
- Objetivo:
  - "abre tu portátil y estás conectado, donde sea"
  - Construir una infraestructura de autenticación interoperable, escalable y segura que podrá ser utilizada en todo el mundo para compartir recursos de red
- Fundamentos:
  - Basado en acceso recíproco (gratuito)
  - La autenticación se realiza en el dominio origen
  - La autorización en la institución visitada
  - Las instituciones de origen son responsables de sus usuarios desplazados
  - Los miembros garantizan los niveles de seguridad requeridos por los participantes
  - Los miembros promoverán el uso de eduroam en sus respectivos países
  - Debe almacenarse la suficiente cantidad de información de log para delimitar responsabilidades

eduroam



- Trust based on RADIUS plus policy documents
- 802.1X
- (VLAN assignment)

Esquema General



http://www.eduroam.es

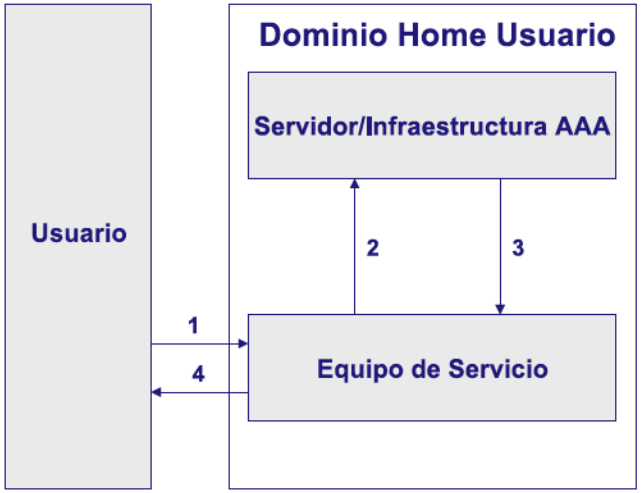
Definición e Implicaciones de las siglas AAA

- **Authentication**: Es el proceso por el cuál se verifica la identidad del usuario. Implica la validación de una credencial presentada por el usuario. Esta credencial puede ser una palabra de paso, un certificado digital, información biométrica, etc.
- **Authorization**: Es el proceso necesario para determinar si un usuario puede o no acceder a un servicio, y bajo qué restricciones/condiciones puede hacerlo.
- **Accounting**: Ofrece los medios necesarios para recoger información sobre el uso de los recursos que el usuario final ha utilizado.

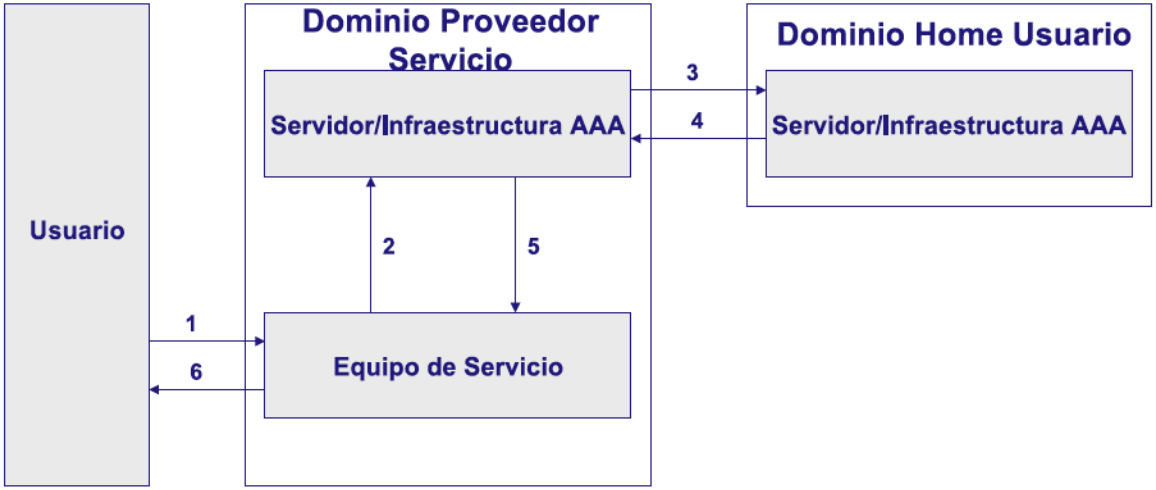
Entidades en una infraestructura AAA

- Las entidades que participan son:
  - U**suario:** quiere acceder a un servicio o recurso ofrecido
  - Un **dominio** con el que el usuario que tiene un acuerdo (*home domain*). Dispone de la información necesaria para verificar la identidad del usuario y si puede obtener el servicio/recurso.
  - Un **proveedor del servicio** que gestiona el acceso al mismo. Este rol puede ser el propio *home domain* u otro dominio visitado por el usuario (*visited domain*).
  - Un **equipo de servicio**. Es un dispositivo, que pertenece al proveedor del servicio, y que suministra el servicio propiamente dicho (p.e. un punto de acceso inalámbrico). También llamado network access server (NAS)

Escenario típico de 802.11i. Modelo pull



(a) Modelo *pull* en un único dominio.



(b) Modelo *pull* en multi-dominio.

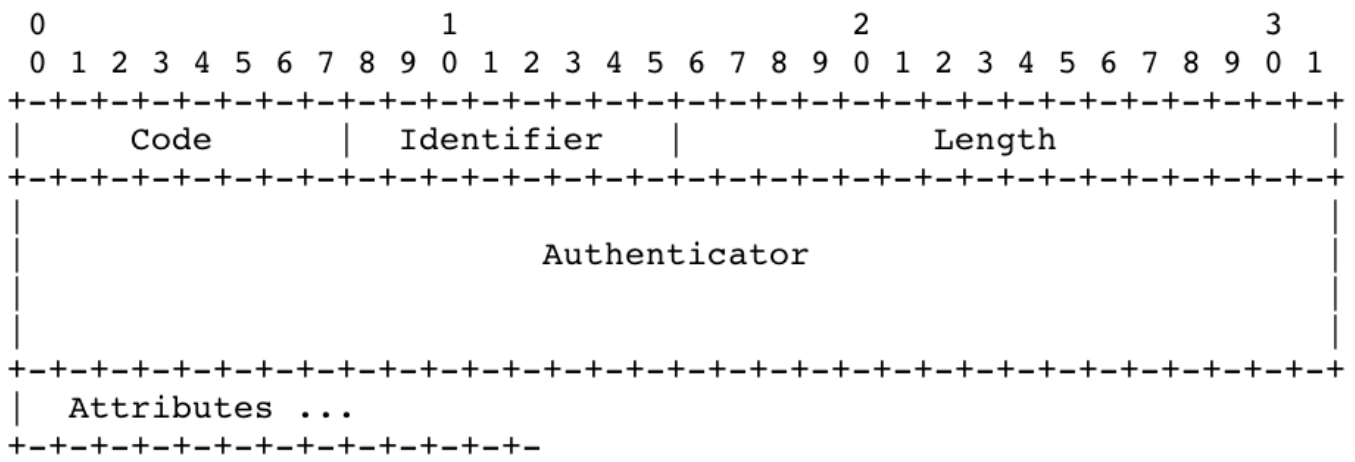
Protocolos AAA

- Requisitos que debería tener un protocolo AAA:
  - Ser capaz de soportar millones de usuarios y miles de solicitudes simultáneas.
  - Soportar entornos multi-dominio.
  - Soportar un proceso de autenticación mutua entre el cliente y el servidor AAA.
  - Permitir el establecimiento de una comunicación segura.
  - Ser extensible para definir nuevos atributos, específicos a un nuevo servicio.
- Protocolos existentes:
  - TACACS, **RADIUS**, COPS, **Diameter**

Protocolo RADIUS

- Diseñado para dar soporte AAA a conexiones PPP
- Simple pero con serias limitaciones.
- Especificado en el RFC 2865 y 2866.
- Modelo Cliente/Servidor
  - Utiliza UDP (puerto 1812 para authentication y authorization, y puerto 1813 para accounting).
  - Pueden existir dos servidores diferentes uno para autenticación y authorization y otro para los datos de accounting.
    - El servidor de auth/authz mantiene una base de datos de los usuarios registrados.
    - El servidor de accounting recoge datos acerca del uso del servicio. (paquetes enviados recibidos por el usuario, tiempo de la conexión)
- Asume una infraestructura AAA simple y estática
- Se utiliza en redes PPP/ADSL, WIFI y WiMax

Formato del mensaje RADIUS

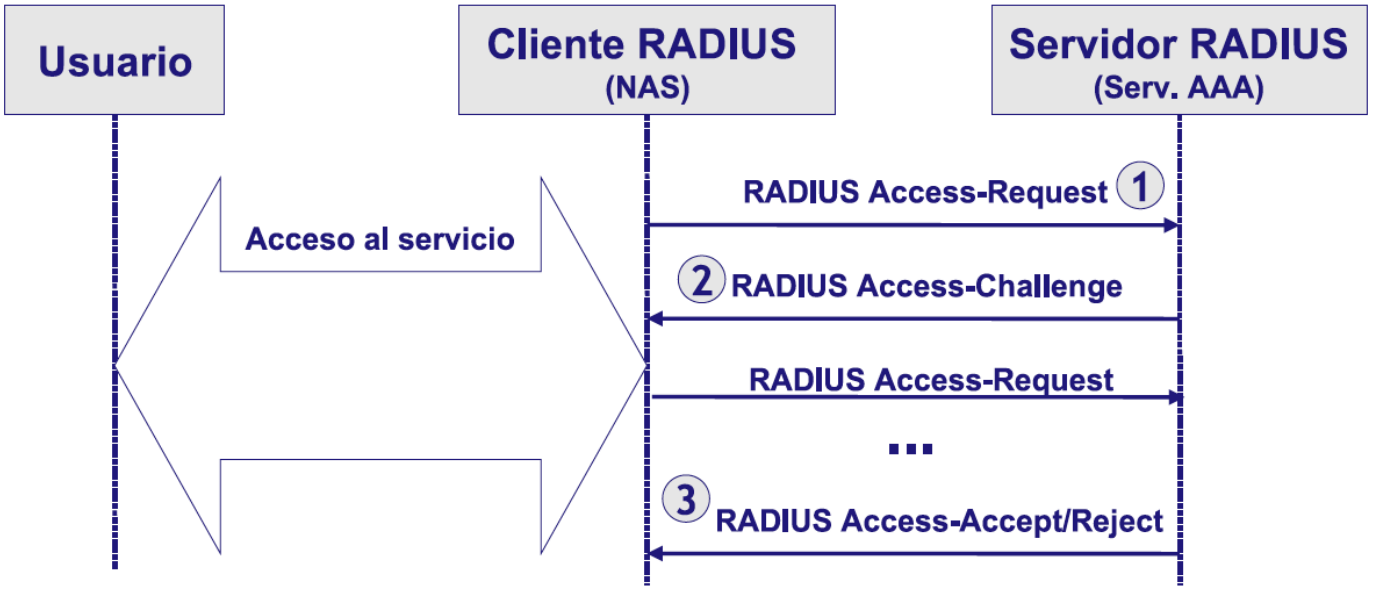


- **Code**. Un octeto que identifica el tipo de mensaje RADIUS.
  - 1 Access-Request
  - 2 Access-Accept
  - 3 Access-Reject
  - 4 Accounting-Request
  - 5 Accounting-Response
  - 11 Access-Challenge
- **Identifier**. Un identificador para relacionar solicitudes con respuestas.
- **Authenticator**. Usado para autenticar el mensaje
- **Attributes**. Contienen la información transportado en RADIUS. Están en formato Tag Longitud Valor (TLV). Máximo 255 bytes

Seguridad en RADIUS

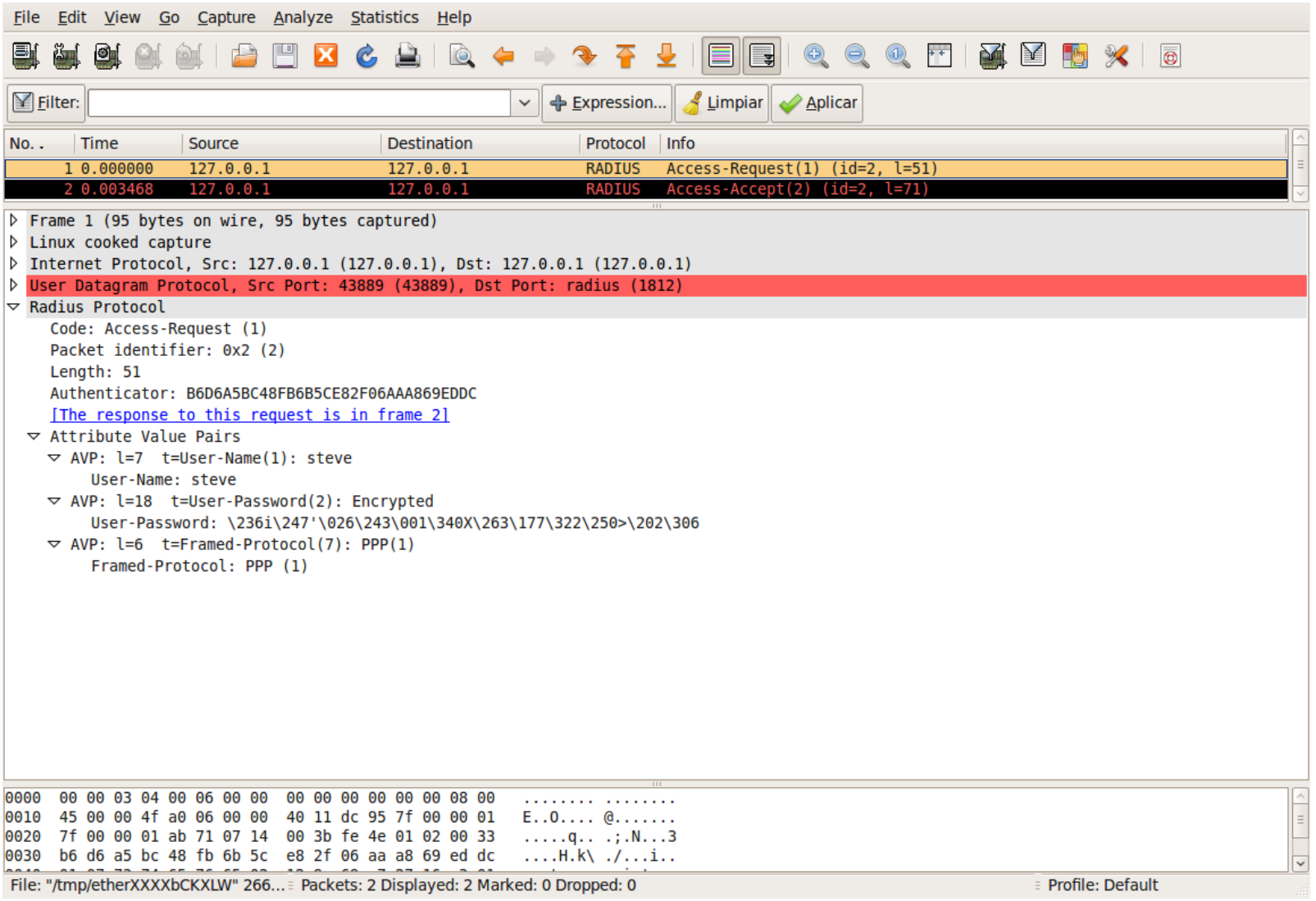
- Seguridad muy débil basado en passwords
- Cliente RADIUS (NAS) y el servidor RADIUS del siguiente salto comparten un password
- El campo authenticator se usa para enviar un número aleatorio (Request Authenticator) al servidor
- Response Authenticator
  - MD5(Code+ID+Length+RequestAuth+Attributes+Secret)
- El mismo challenge es usado para proteger el User-Password:
  - MD5(Secret + Request Authenticator) XOR User's Password

Funcionamiento general

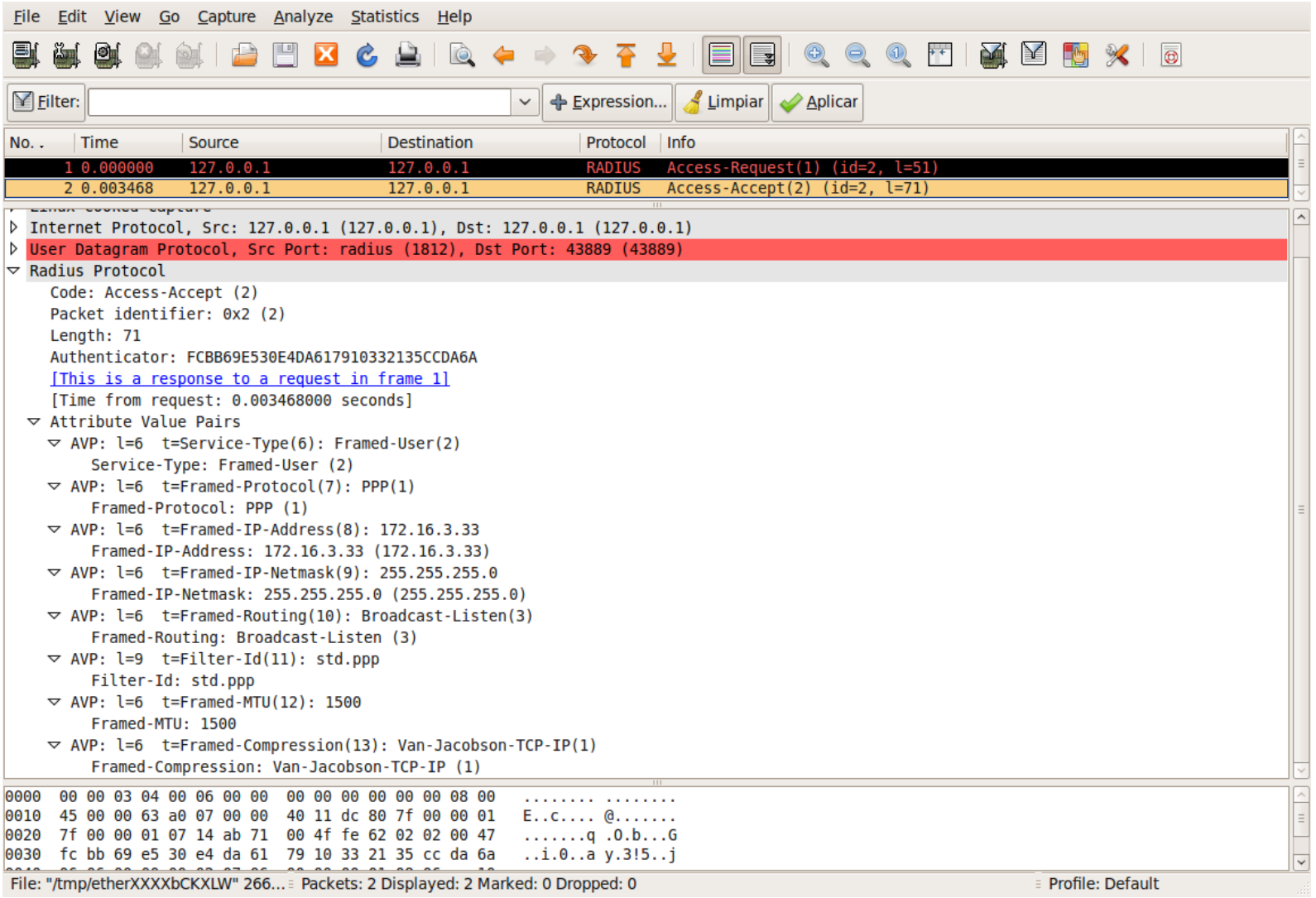


- El NAS interactúa con el usuario y obtiene datos de autenticación que envía al Servidor RADIUS a través de un *RADIUS Access-Request* (1).
- Si servidor RADIUS necesita más datos de autenticación del usuario responde con un *RADIUS Access-Challenge*.(2)
- El proceso finaliza con una verificación exitosa (*RADIUS Access-Accept*) o con un fallo de autenticación (*RADIUS Access-Reject*)(3)

Ejemplo RADIUS Access Request

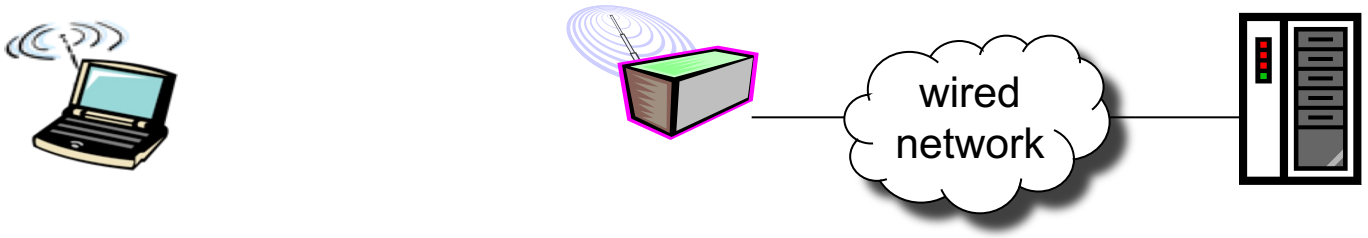


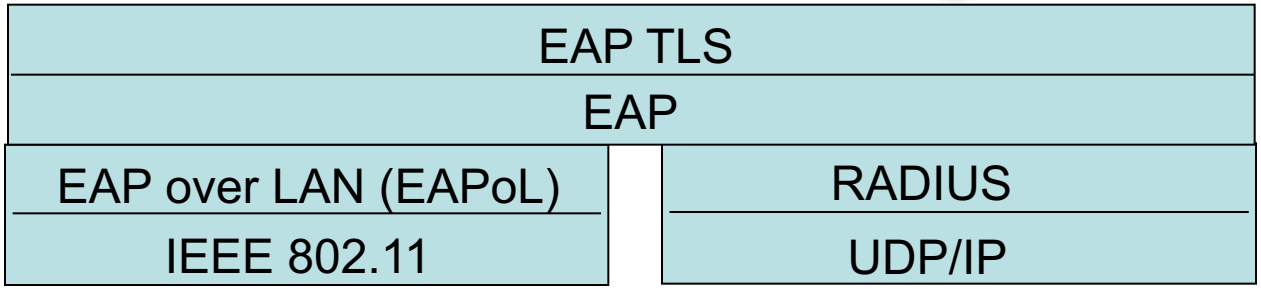
Ejemplo RADIUS Access Accept



Autenticación en 802.11i con servidores

- Objetivos:
  - Evitar la necesidad de tener que compartir claves de forma predeterminada.
  - Poder realizar una autenticación mutua, puesto que hasta ahora la infraestructura no se ha autenticado.
  - Permitir varios métodos de autenticación posibles.
- Uso de la Arquitectura 802.1X



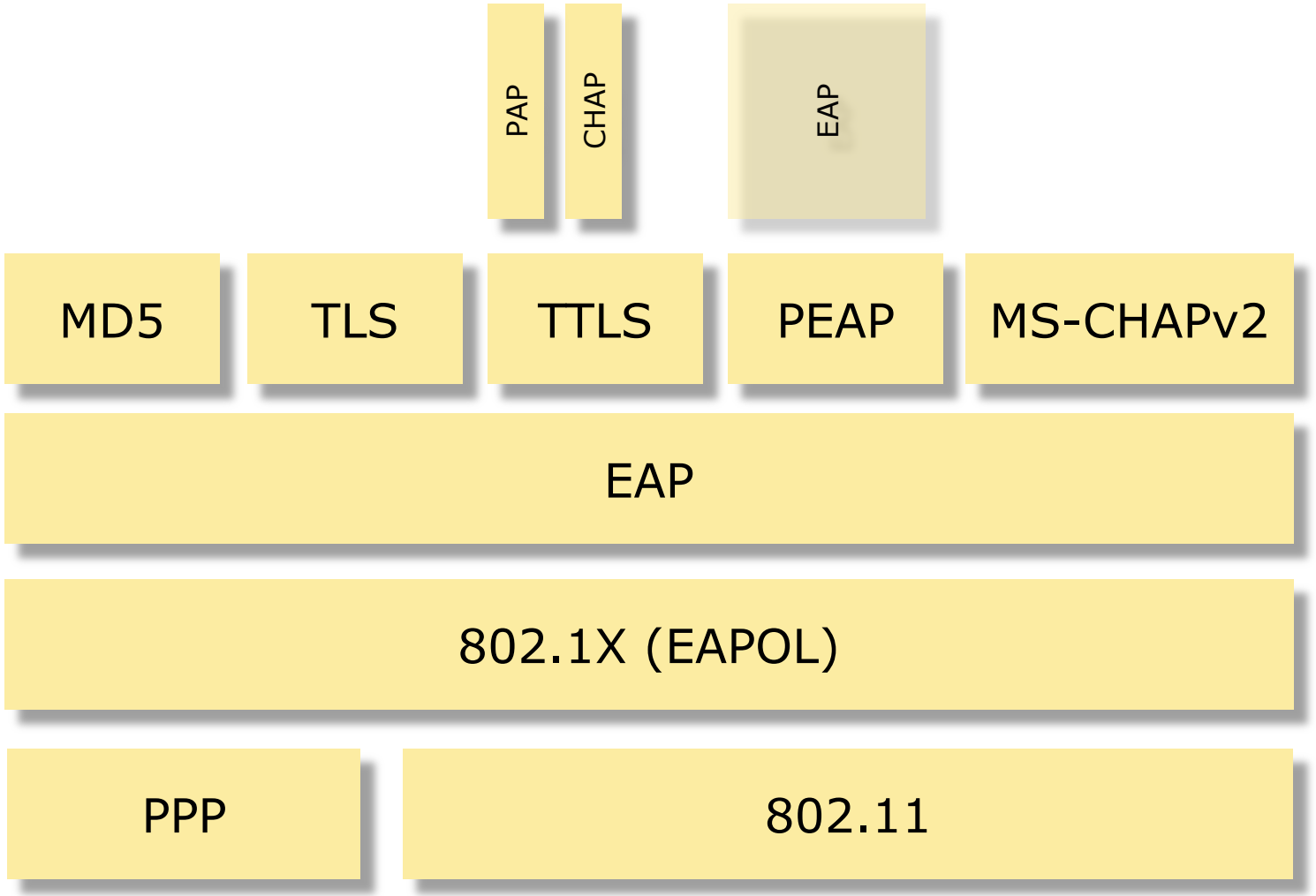


Extensible Authentication Protocol (EAP)

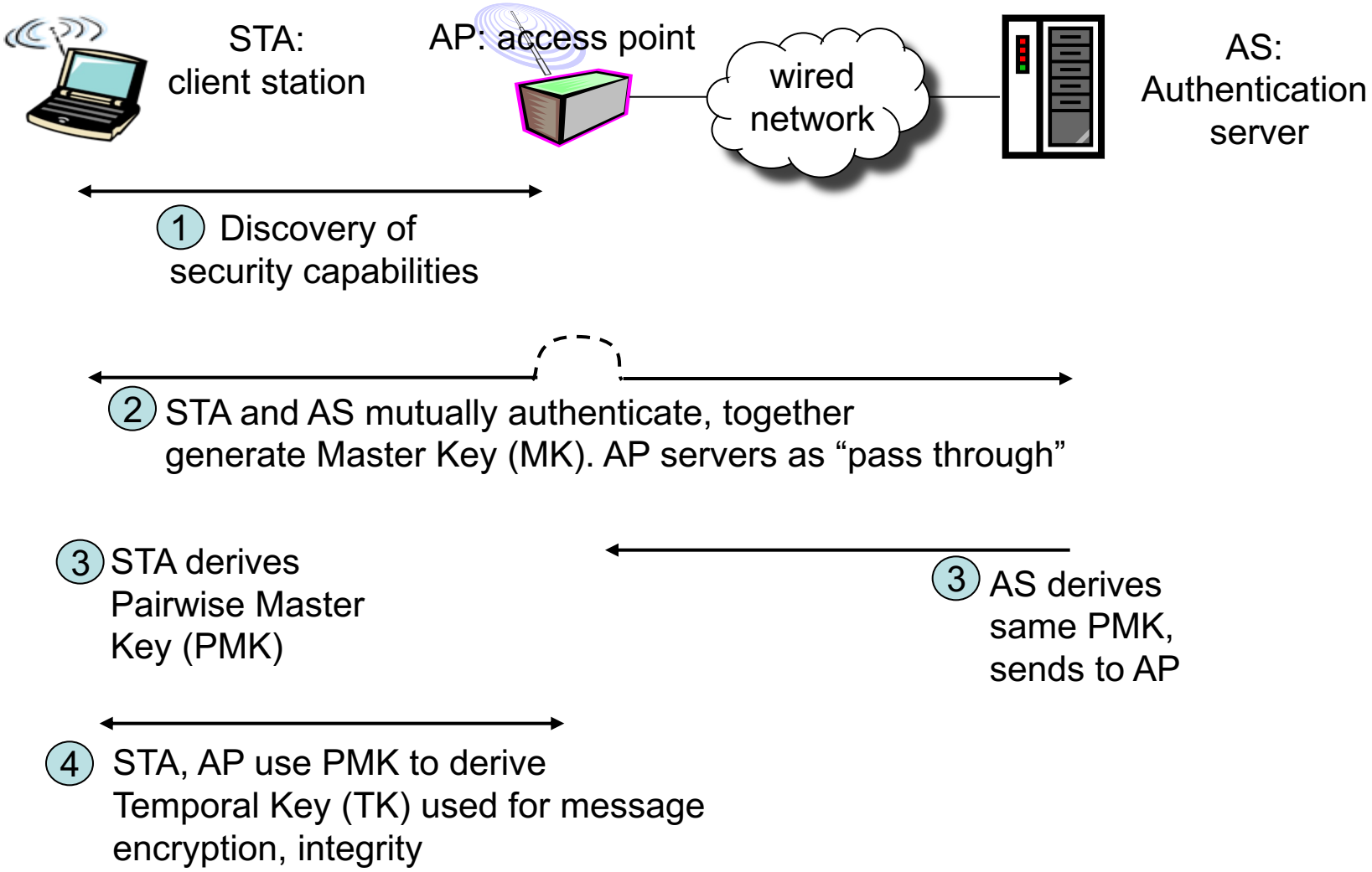
- Las infrastructuras AAA dan soporte al proceso de autenticación y autorización, pero ofrecen flexibilidad a la hora de realizar estos procesos.
- EAP es independiente del nivel de enlace, y permite ejecutar de manera flexible diferentes mecanismos de autenticación denominados *métodos EAP*.
- Los métodos EAP son ejecutados entre un peer EAP y un servidor EAP a través de un autenticador EAP que simplemente se encarga de reenviar los paquetes EAP intercambiados entre las dos entidades, con la intención de completar el proceso de autenticación.
- El servidor EAP normalmente está situado en un servidor AAA.

EAP

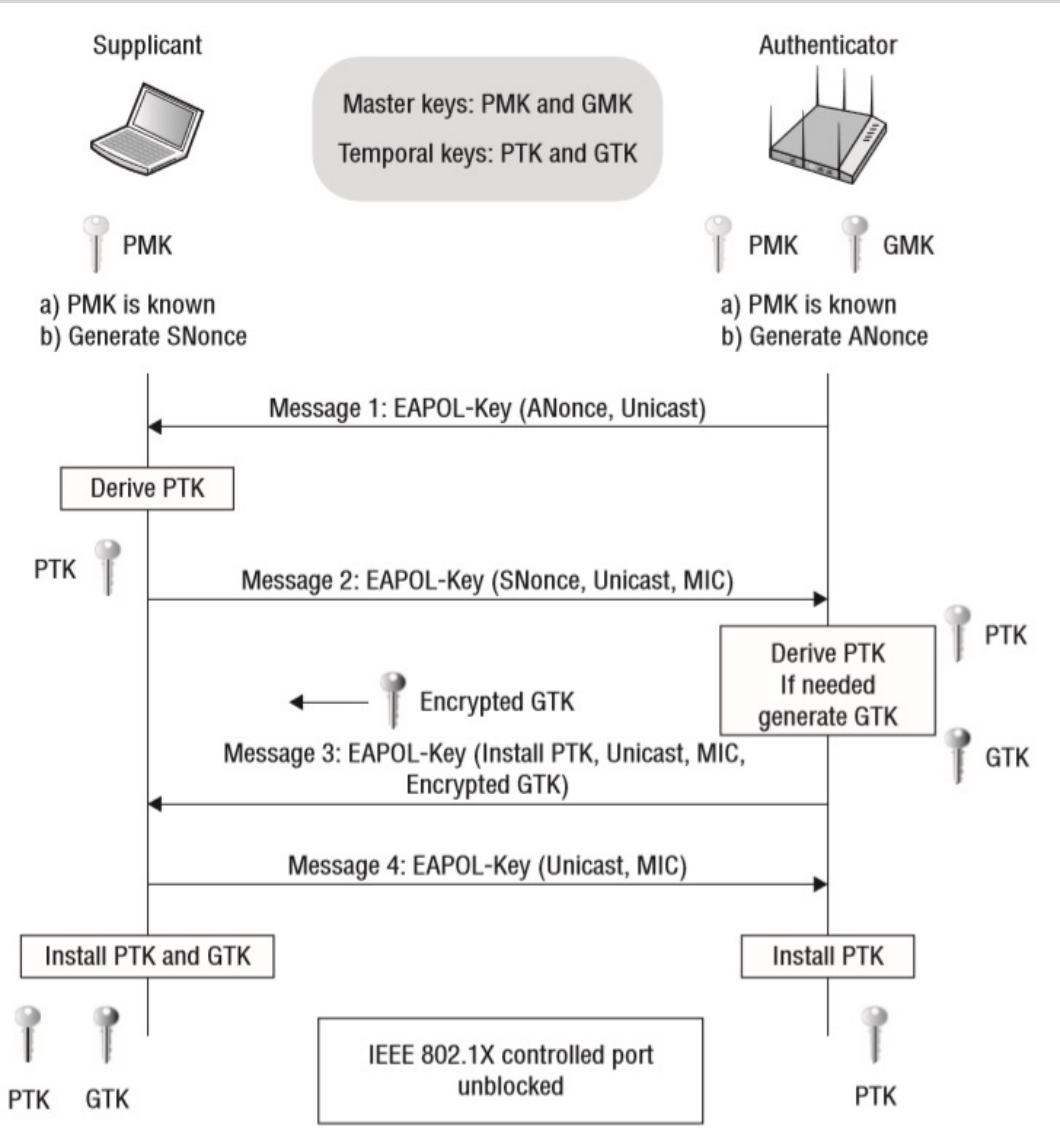
- Soporte para múltiples métodos de autenticación



Uso de servidores de autenticación



Derivación de claves con EAPOL



WEP

- WEP (Wired Equivalent Privacy)
  - Fue diseñado para proporcionar tres servicios básicos de seguridad a las comunicaciones inalámbricas:
    1. Impedir la interceptación de la información: confidencialidad.
    2. Permitir el acceso a la red inalámbrica a aquellos dispositivos que estén autorizados: disponibilidad.
    3. Evitar la suplantación de cualquier comunicación inalámbrica: integridad.
  - Está basado en el cifrador de flujo RC4
  - Se aplica al cuerpo de la trama y al CRC
  - Usa claves de 40 o 104 bits y vectores de inicialización (IV) de 24 bits.
  - Los IVs cambian por cada trama, aunque el procedimiento de generación no es estándar.

WEP

- Ataques sobre WEP
  - Basados en el artículo "*Weaknesses in the Key Scheduling Algorithm of RC4*" de Fluhrer, Mantin y Shamir (2001)
  - Basados en la existencia de IVs débiles
  - El ataque se basa en una debilidad del algoritmo de generación del flujo de claves y en la posibilidad de conocer texto plano
  - Ataques posibles:
    - Texto plano conocido: a partir de secuencias de protocolos comunes
    - Construcción de diccionarios de IVs
    - Ataques de inyección de tráfico: repetición de paquetes, permutación de bits, inyección de paquetes encriptados, inyección por dos extremos.

802.11i

- WPA es una versión pre-estándar de 802.11i que fue lanzada por los fabricantes previamente
- WPA2 es el nombre comercial del 802.11i
- Componentes
  - Uso de RSN (Robust Security Network) para la negociación dinámica de las suites de autenticación y de cifrado
  - Soporte para EAP (Extensible Authentication Protocol) de cara a incorporar varios métodos de autenticación
  - Uso de 802.1X para el intercambio de información entre clientes no autorizados y elementos de la infraestructura
  - Uso de claves compartidas para el caso de que no haya soporte de autenticación mediante RADIUS.
  - Las claves compartidas son claves maestras con las cuales generar claves de sesión temporales.

Wi-Fi Protected Setup

- Descripción general:
  - Creado por la Wi-Fi Alliance, su propósito es permitir a los usuarios con escasos conocimientos técnicos poder establecer redes de forma segura.
- Métodos de autenticación:
  - Método PIN. Funciona en ambos sentidos e implica que un PIN mostrado en un dispositivo (sea una STA o un AP) debe ser introducido en el otro.
  - Push-Button. En este caso basta con pulsar un botón (físico o virtual) en ambos dispositivos para establecer la comunicación.
  - Intercambio de los valores de configuración mediante NFC
- Debilidades:
  - Algunos de ellos son susceptibles de ser atacados mediante fuerza bruta

Wi-Fi Protected Setup

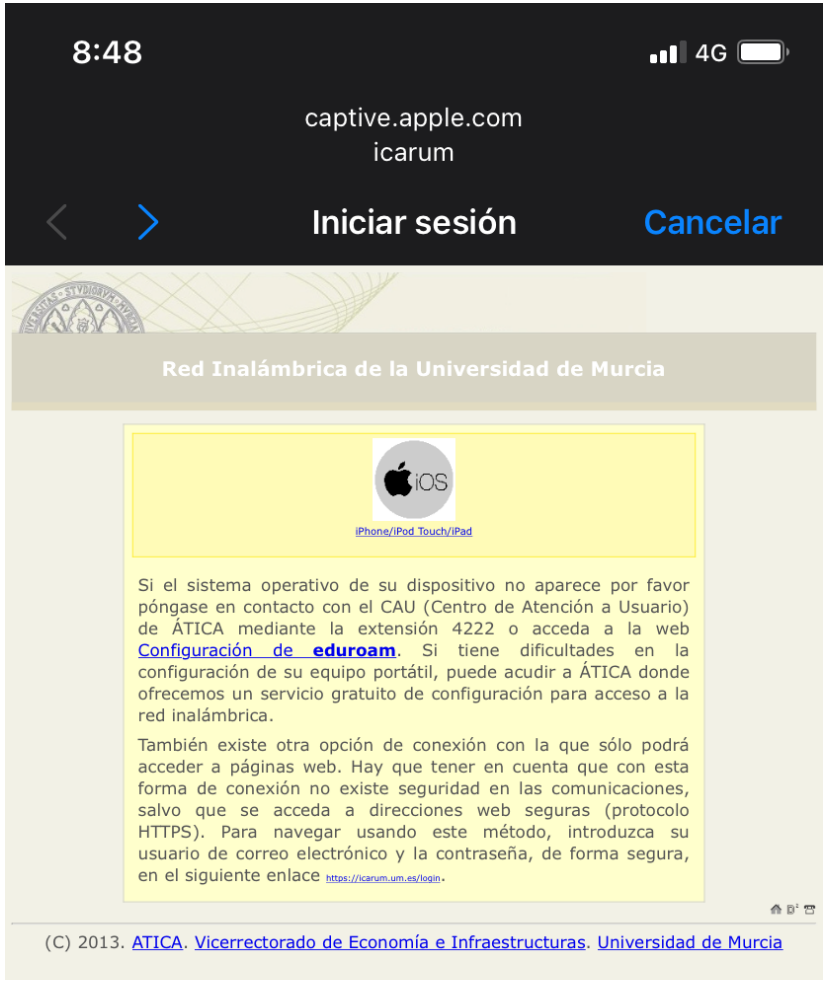
Authentication (PIN – External Registrar)[4]

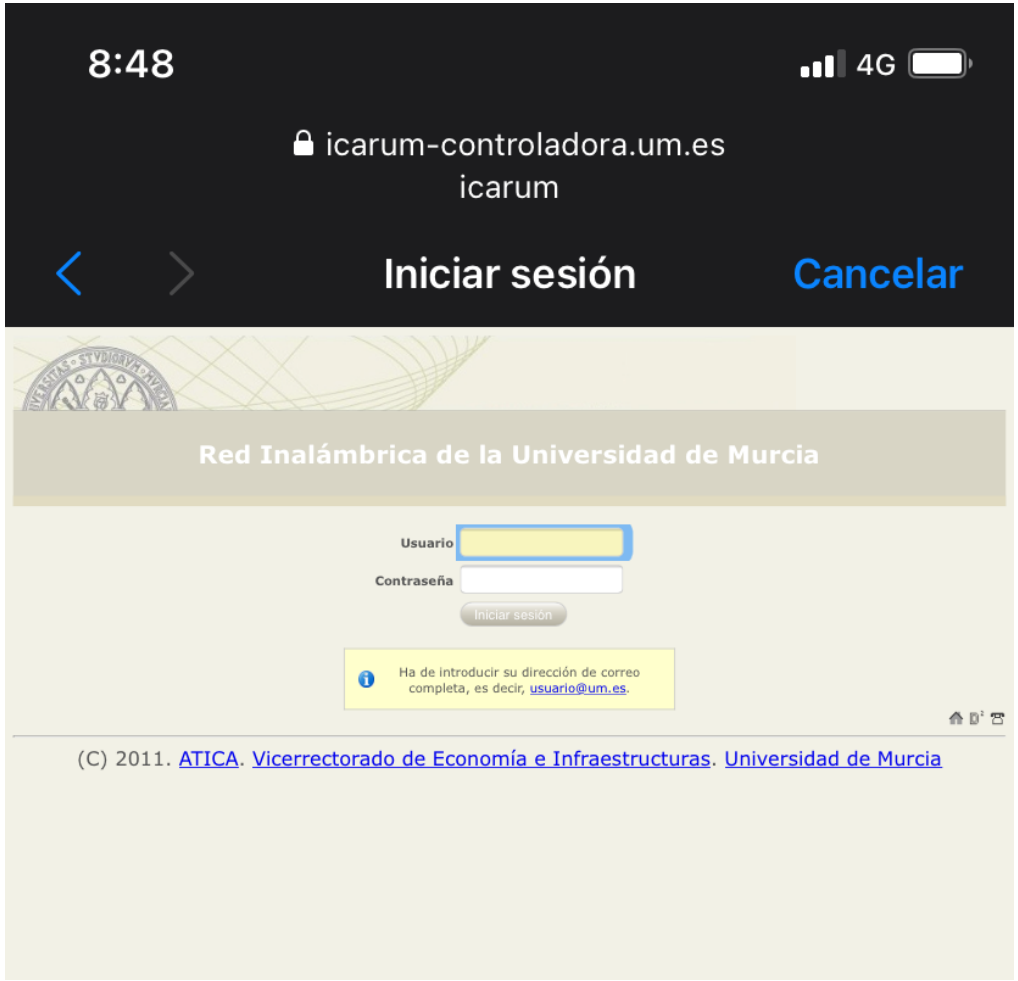
IEEE 802.11			
	Supplicant → AP	Authentication Request	802.11 Authentication
	Supplicant ← AP	Authentication Response	
	Supplicant → AP	Association Request	802.11 Association
	Supplicant ← AP	Association Response	
IEEE 802.11/EAP			
	Supplicant → AP	EAPOL-Start	EAP Initiation
	Supplicant ← AP	EAP-Request Identity	
	Supplicant → AP	EAP-Response Identity (Identity: "WFA-SimpleConfig-Registrar-1-0")	
IEEE 802.11/EAP Expanded Type, Vendor ID: WFA (0x372A), Vendor Type: SimpleConfig (0x01)			
M1	Enrollee → Registrar	N1 || Description || PK_E	Diffie-Hellman Key Exchange
M2	Enrollee ← Registrar	N1 || N2 || Description || PK_R || Authenticator	
M3	Enrollee → Registrar	N2 || E-Hash1 || E-Hash2 || Authenticator	
M4	Enrollee ← Registrar	N1 || R-Hash1 || R-Hash2 || $E_{KevWrapKev}$(R-S1) || Authenticator	proove posession of 1st half of PIN
M5	Enrollee → Registrar	N2 || $E_{KeyWrapKey}$(E-S1) || Authenticator	proove posession of 1st half of PIN
M6	Enrollee ← Registrar	N1 || $E_{KeyWrapKey}$(R-S2) || Authenticator	proove posession of 2nd half of PIN
M7	Enrollee → Registrar	N2 || $E_{KeyWrapKey}$(E-S2 ||ConfigData) || Authenticator	proove posession of 2nd half of PIN, send AP configuration
M8	Enrollee ← Registrar	N1 || $E_{KeyWrapKey}$(ConfigData) || Authenticator	set AP configuration

Portal cautivo

- Cuando un cliente intenta navegar por Internet es automáticamente redirigido a una página de autenticación
  - Obtiene una dirección privada por DHCP
- Los métodos de autenticación pueden ser muy diversos
  - Login + password
  - Uso de certificados
- Se consigue mediante la interceptación y la redirección del tráfico HTTP hacia el portal
- En función de la autenticación, la pasarela modificará los parámetros de funcionamiento de la red
- Varias soluciones:
  - ChilliSpot, NoCat, Wifidog, Talweg, Opengate

Portal cautivo





Portal cautivo

- Componentes
  - Los clientes móviles o usuarios finales
  - Los puntos de acceso
    - Redireccionan todo el tráfico hasta las pasarelas inalámbricas
  - Las pasarelas inalámbricas
    - Regulan el tráfico en base a las decisiones del servicio de autenticación
  - Los servicios de autenticación
    - Mantienen las BD de los miembros y sus credenciales
    - Reciben peticiones de autenticación
    - Notifican a la pasarelas los cambios en los cortafuegos de acceso

Portal cautivo

- Componentes

